



Carrera tecnica de cybersecurity

Titulo

Endurecimiento de Superficie de Ataque (Windows)

Autor

Pedro David Then Bido

Matricula

21430

Maestro

Juan Emilio Mateo Mella

Santo Domingo

Republica Dominicana

15 Mayo 2026

1. Deshabilitar el protocolo SMBv1	3
2. Deshabilitar cuentas innecesarias.....	4
3. Renombrar la cuenta Administrador	5
4. Renombrar la cuenta Administrador local de las estaciones de trabajo	6
Riesgo mitigado	6
Validación técnica.....	6
5. Configurar políticas de complejidad y expiración de contraseñas	7
6. Configurar políticas de bloqueo de cuentas.....	8
7. Configurar bloqueo automático de pantalla por inactividad	9
8. Deshabilitar almacenamiento de credenciales en Credential Manager.....	9
9. Habilitar y configurar Windows Defender Firewall	10

Endurecimiento de Superficie de Ataque en Windows

Informe técnico de hardening basado en recomendaciones CIS Benchmark.
Sistema utilizado: Windows Server 2022

Introducción

En esta práctica se realizaron diferentes configuraciones de seguridad en Windows con el objetivo de reducir la superficie de ataque del sistema. Las configuraciones aplicadas ayudan a fortalecer la seguridad del servidor, evitando vulnerabilidades comunes, ataques de fuerza bruta y accesos no autorizados.

Objetivo

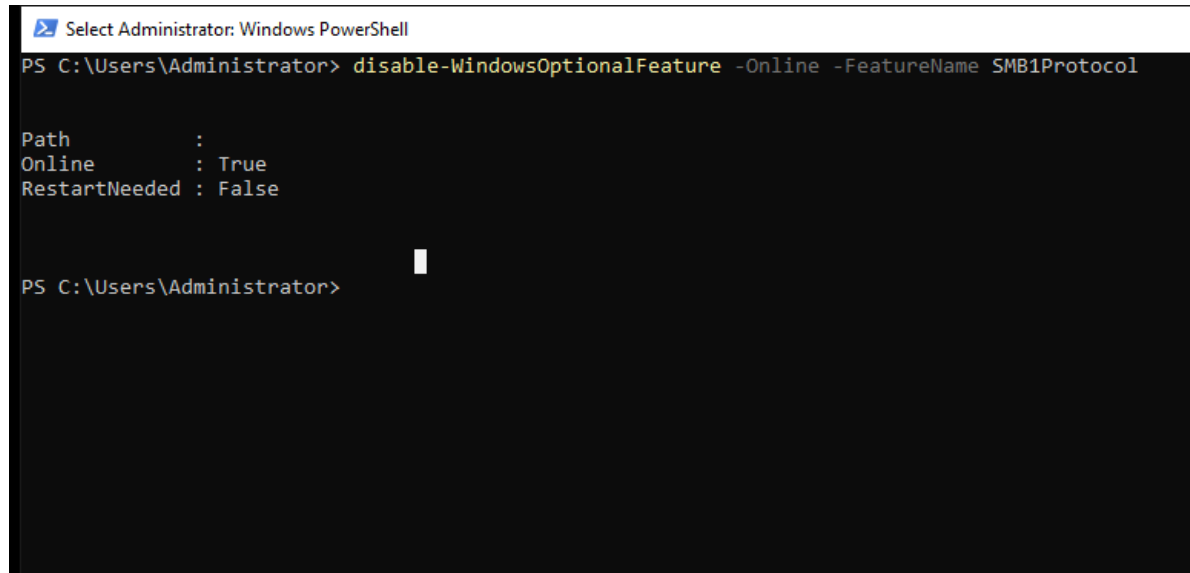
Aplicar configuraciones de hardening en Windows siguiendo buenas prácticas de seguridad recomendadas por CIS Benchmark para mejorar la protección del sistema operativo.

1. Deshabilitar el protocolo SMBv1

Descripción: Se deshabilitó el protocolo SMBv1 debido a que es un protocolo antiguo y vulnerable utilizado en ataques como WannaCry y EternalBlue.

Riesgo mitigado: Reduce el riesgo de ransomware, ejecución remota de código y movimiento lateral.

Validación: La validación se realizó mediante PowerShell verificando que SMBv1 quedara deshabilitado.



```
Select Administrator: Windows PowerShell
PS C:\Users\Administrator> disable-WindowsOptionalFeature -Online -FeatureName SMB1Protocol

Path      :
Online    : True
RestartNeeded : False

PS C:\Users\Administrator>
```

```
Administrator: Windows PowerShell
PS C:\Users\Administrator> Get-WindowsOptionalFeature -Online -FeatureName SMB1Protocol

FeatureName      : SMB1Protocol
DisplayName       : SMB 1.0/CIFS File Sharing Support
Description       : Support for the SMB 1.0/CIFS file sharing protocol, and the Computer Browser protocol.
RestartRequired  : Possible
State            : Disabled
CustomProperties  :
                    ServerComponent\Description : Support for the SMB 1.0/CIFS file sharing protocol, and the
                    Computer Browser protocol.
                    ServerComponent\DisplayName : SMB 1.0/CIFS File Sharing Support
                    ServerComponent\Id          : 487
                    ServerComponent\Type        : Feature
                    ServerComponent\UniqueName  : FS-SMB1
                    ServerComponent\Deploys\Update\Name : SMB1Protocol

PS C:\Users\Administrator>
```

2. Deshabilitar cuentas innecesarias

Descripción: Se revisaron los usuarios locales del sistema y se deshabilitó la cuenta Guest para evitar accesos no autorizados.

Riesgo mitigado: Disminuye riesgos asociados a cuentas olvidadas o sin uso.

Validación: Se utilizó Get-LocalUser para verificar que la cuenta Guest estuviera deshabilitada.

```
Administrator: Windows PowerShell

Install the latest PowerShell for new features and improvements! https://aka.ms/PSWindows

PS C:\Users\Administrator> Get-LocalUser

Name      Enabled Description
-----
Administrator True    Built-in account for administering the computer/domain
Guest      False   Built-in account for guest access to the computer/domain
krbtgt     False   Key Distribution Center Service Account
cmendez    False
jperez     True
alopez     True
ltorres    True
mdiaz      True
pgomez     True
jrodriguez True
lcastillo  True
mramirez   True
sherrera   True
anuñez     True
dcruz      True
psantos    True
mpeña      True
rvarga     True
lmedina    True
jacosta    True
ecabreara  True
dmolina    True
kflores    True
rsalas     True
lperez     True
aruiz      True
mvega      True
sherrea    True
```

```
Administrator: Windows PowerShell
SDQ-DC-SVR01$ True

PS C:\Users\Administrator> Disable-LocalUser -Name "Guest"
PS C:\Users\Administrator> Get-LocalUser

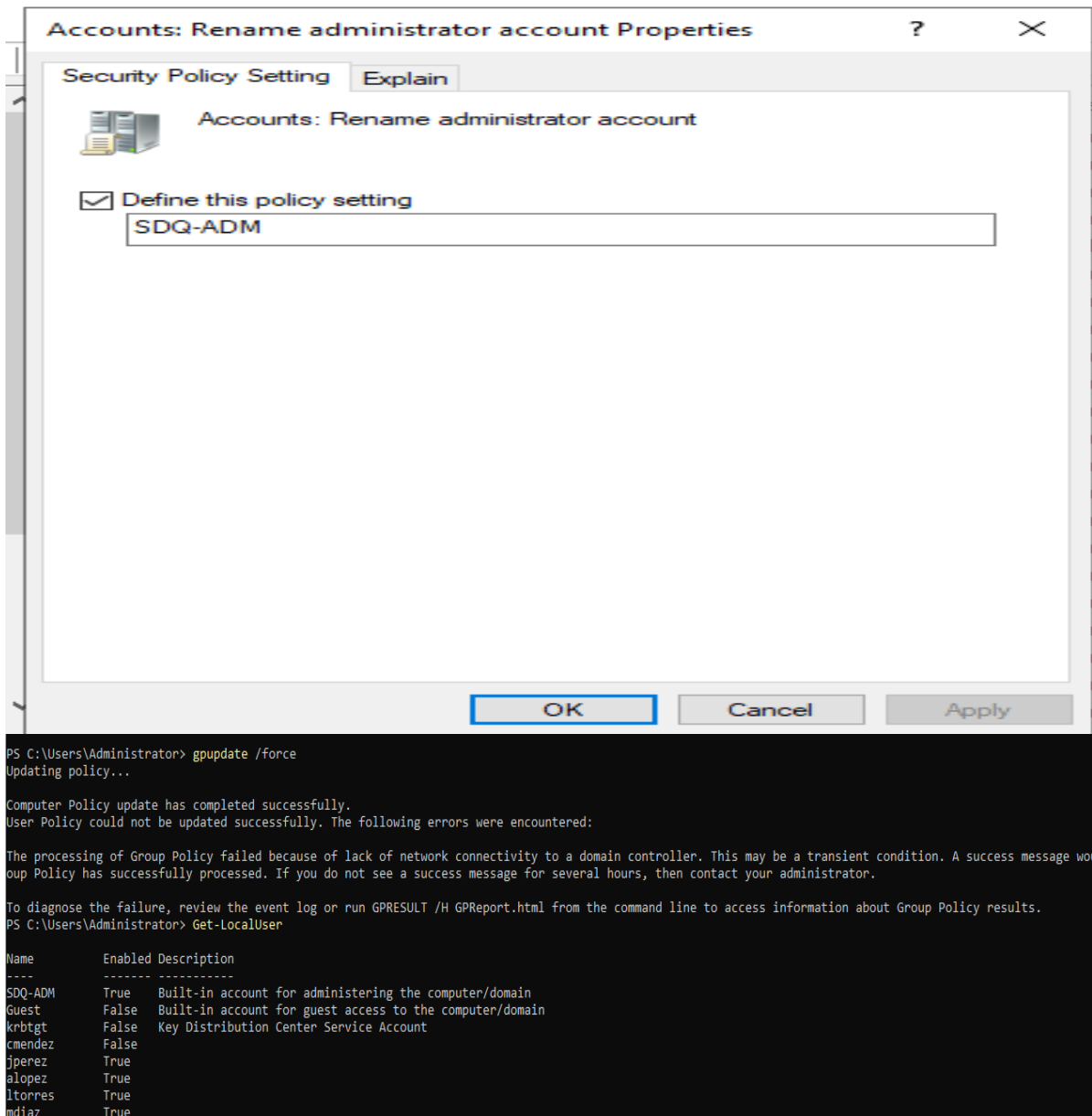
Name           Enabled Description
----
Administrator True    Built-in account for administering the computer/domain
Guest          False   Built-in account for guest access to the computer/domain
krbtgt         False   Key Distribution Center Service Account
cmendez        False
jperez         True
alopez         True
ltorres        True
mdiaz          True
pgomez         True
jrodriguez     True
lcastillo      True
mramirez       True
sherrera       True
anuñez         True
dcruz          True
psantos        True
mpeña          True
rvarga         True
lmedina        True
jacosta        True
ecabreara      True
dmolina        True
kflores        True
rsalas         True
lperez         True
aruiz          True
mvega         True
```

3. Renombrar la cuenta Administrador

Descripción: La cuenta Administrator fue renombrada a SDQ-ADM utilizando políticas de grupo.

Riesgo mitigado: Reduce ataques automáticos dirigidos a cuentas administrativas conocidas.

Validación: Se verificó mediante GPO y PowerShell que el nuevo nombre fue aplicado correctamente.



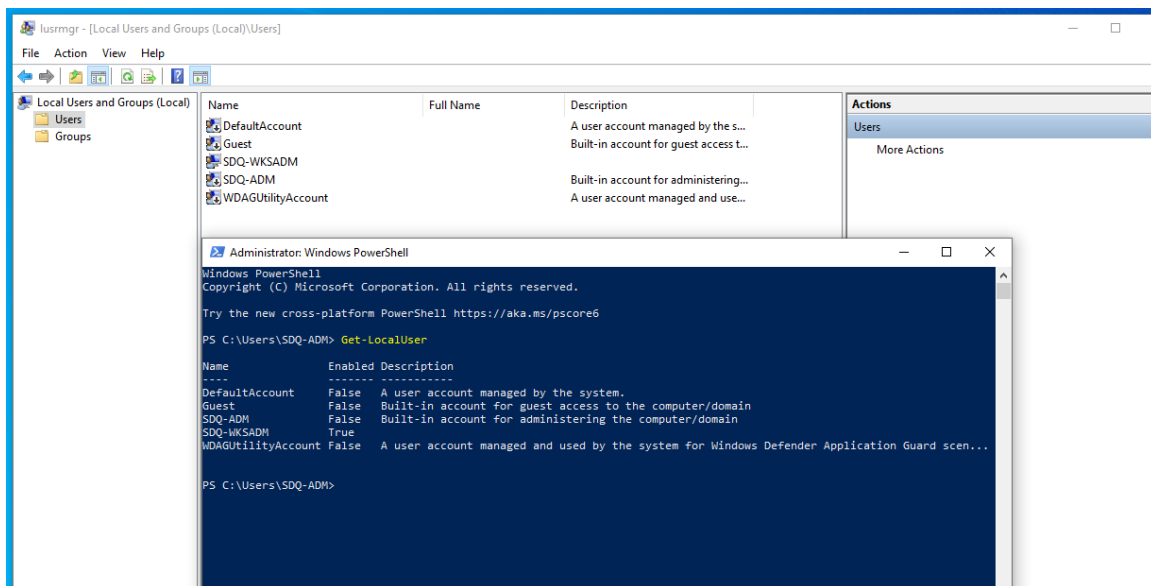
4. Renombrar la cuenta Administrador local de las estaciones de trabajo

Riesgo mitigado

El cambio de nombre de la cuenta Administrador local ayuda a reducir ataques de fuerza bruta y ataques automatizados dirigidos a cuentas administrativas conocidas.

Validación técnica

Comando utilizado: Get-LocalUser

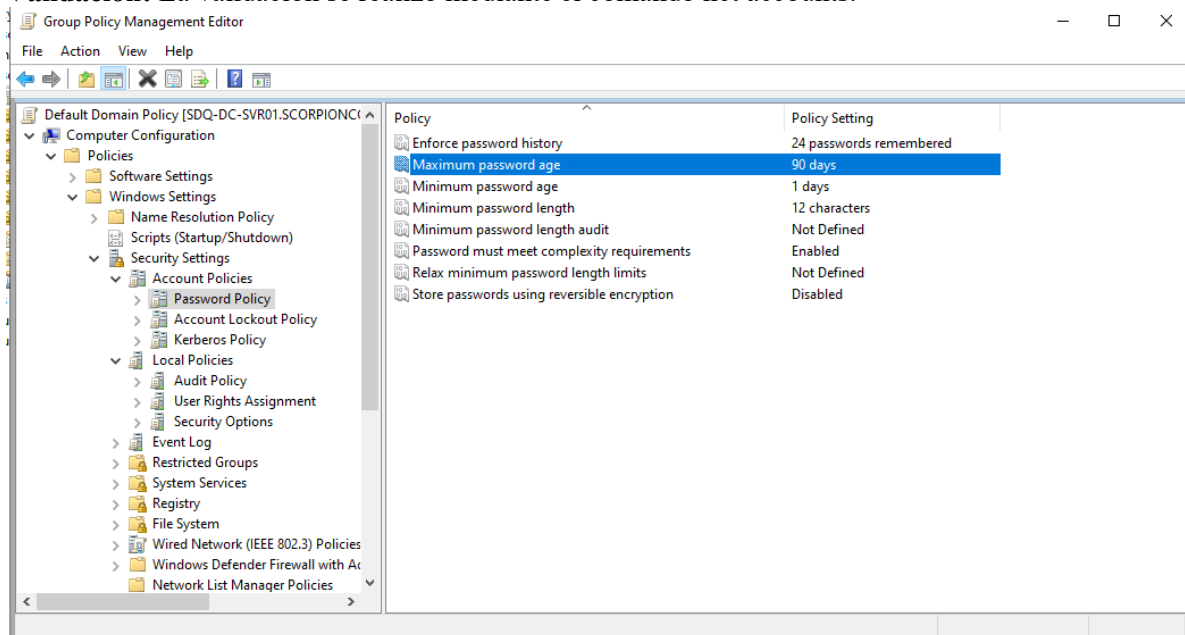


5. Configurar políticas de complejidad y expiración de contraseñas

Descripción: Se configuraron políticas de complejidad, longitud mínima, historial y expiración de contraseñas.

Riesgo mitigado: Reduce el uso de contraseñas débiles y evita reutilización.

Validación: La validación se realizó mediante el comando `net accounts`.



```
Administrator: Windows PowerShell
Windows PowerShell
Copyright (C) Microsoft Corporation. All rights reserved.

Install the latest PowerShell for new features and improvements! https://aka.ms/PSWindows

PS C:\Users\Administrator> net accounts
Force user logoff how long after time expires?: Never
Minimum password age (days): 1
Maximum password age (days): 90
Minimum password length: 12
Length of password history maintained: 24
Lockout threshold: Never
Lockout duration (minutes): 30
Lockout observation window (minutes): 30
Computer role: PRIMARY
The command completed successfully.

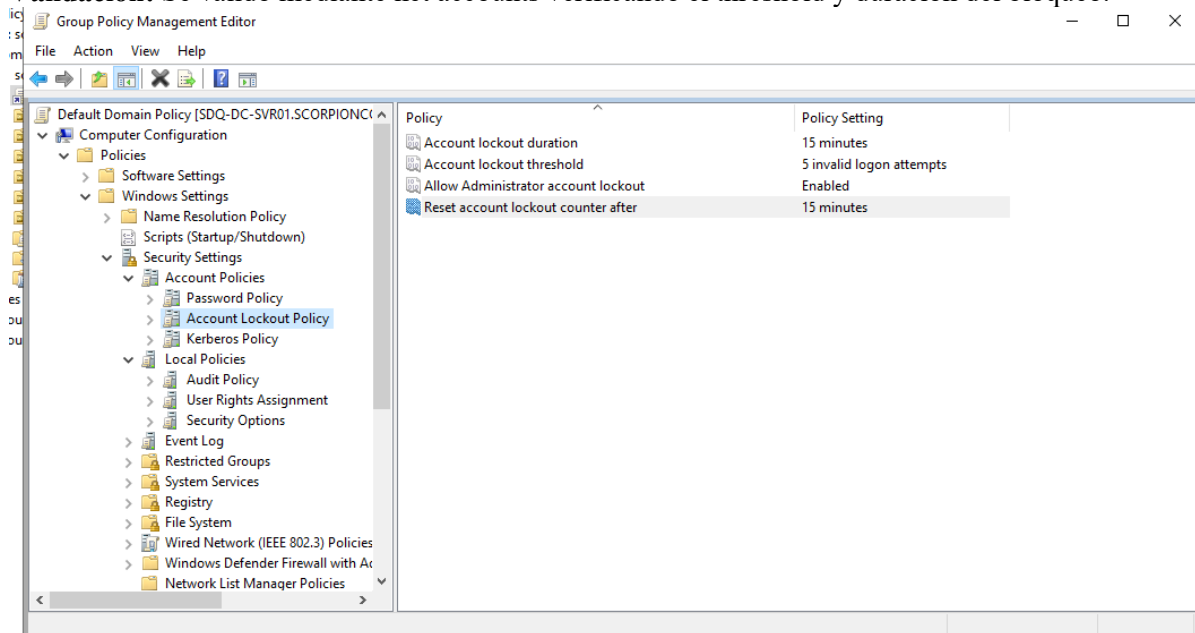
PS C:\Users\Administrator>
```

6. Configurar políticas de bloqueo de cuentas

Descripción: Se configuró el bloqueo de cuentas después de varios intentos fallidos de inicio de sesión.

Riesgo mitigado: Ayuda a mitigar ataques de fuerza bruta y password spraying.

Validación: Se validó mediante net accounts verificando el threshold y duración del bloqueo.




```
Administrator: Windows PowerShell
Windows PowerShell
Copyright (C) Microsoft Corporation. All rights reserved.

PS C:\Users\Administrator> net accounts
Force user logoff how long after time expires?:      Never
Minimum password age (days):                       1
Maximum password age (days):                       90
Minimum password length:                            12
Length of password history maintained:               24
Lockout threshold:                                  5
Lockout duration (minutes):                          15
Lockout observation window (minutes):                10
Computer role:                                       PRIMARY
The command completed successfully.

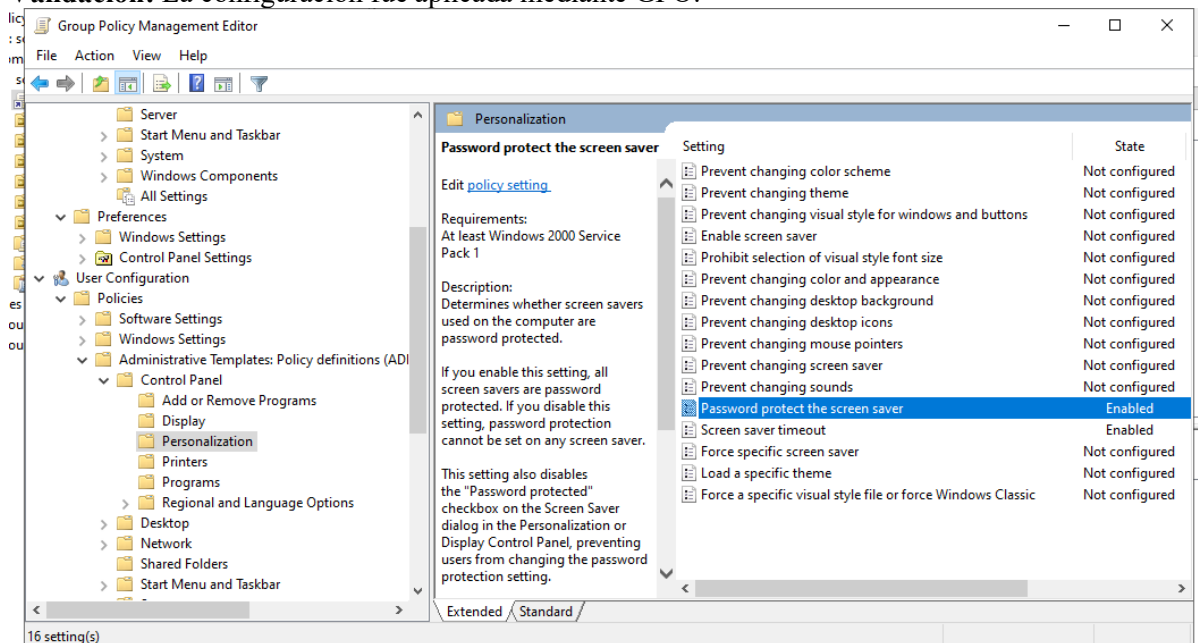
PS C:\Users\Administrator>
```

7. Configurar bloqueo automático de pantalla por inactividad

Descripción: Se habilitó el protector de pantalla con bloqueo automático después de inactividad.

Riesgo mitigado: Evita accesos físicos no autorizados cuando el equipo queda desatendido.

Validación: La configuración fue aplicada mediante GPO.

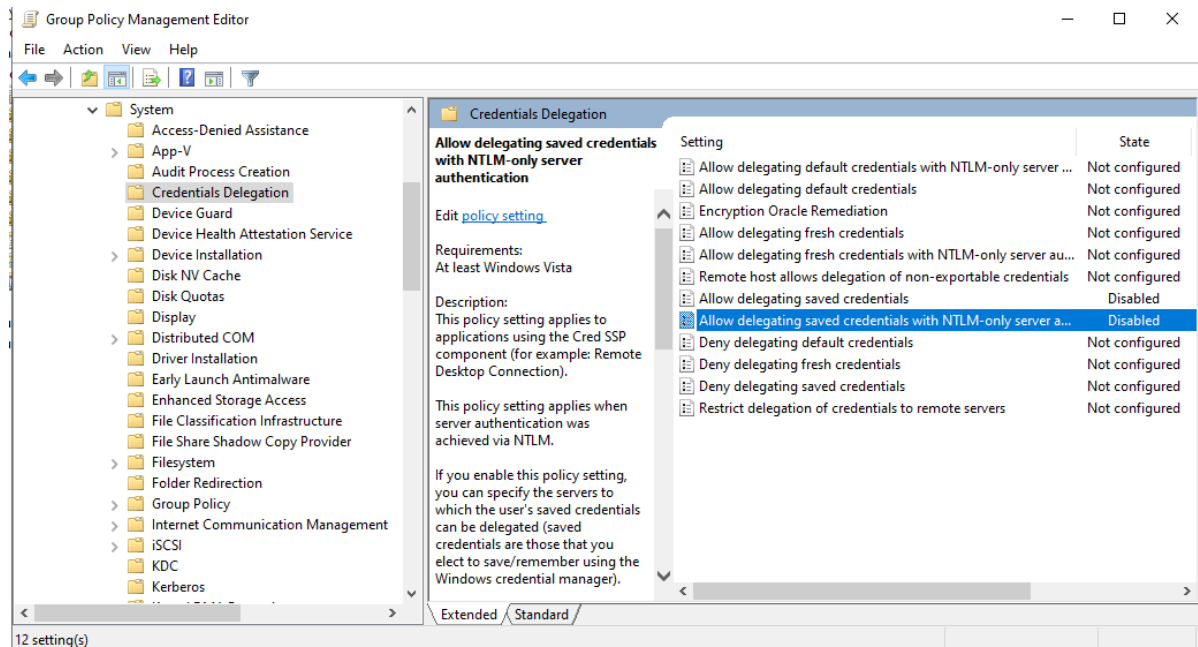


8. Deshabilitar almacenamiento de credenciales en Credential Manager

Descripción: Se deshabilitó la delegación y almacenamiento de credenciales guardadas.

Riesgo mitigado: Reduce riesgos de robo de credenciales y abuso de sesiones RDP.

Validación: La configuración fue validada desde Group Policy.



9. Habilitar y configurar Windows Defender Firewall

Descripción: Se habilitó Windows Defender Firewall para los perfiles Domain, Private y Public.

Riesgo mitigado: Ayuda a controlar conexiones entrantes y salientes no autorizadas.

Validación: La validación se realizó mediante Get-NetFirewallProfile.

```

PS C:\Users\Administrator> Set-NetFirewallProfile -Profile Domain,Public,Private -Enabled true
PS C:\Users\Administrator> Get-NetFirewallProfile

Name                : Domain
Enabled              : True
DefaultInboundAction : NotConfigured
DefaultOutboundAction : NotConfigured
AllowInboundRules    : NotConfigured
AllowLocalFirewallRules : NotConfigured
AllowLocalIPsecRules : NotConfigured
AllowUserApps        : NotConfigured
AllowUserPorts       : NotConfigured
AllowUnicastResponseToMulticast : NotConfigured
NotifyOnListen       : False
EnableStealthModeForIPsec : NotConfigured
LogFileName          : %systemroot%\system32\LogFiles\Firewall\pfirewall.log
LogMaxSizeKilobytes  : 4096
LogAllowed            : False
LogBlocked            : False
LogIgnored            : NotConfigured
DisabledInterfaceAliases : {NotConfigured}

Name                : Private
Enabled              : True
DefaultInboundAction : NotConfigured
DefaultOutboundAction : NotConfigured
AllowInboundRules    : NotConfigured
AllowLocalFirewallRules : NotConfigured
AllowLocalIPsecRules : NotConfigured
AllowUserApps        : NotConfigured
AllowUserPorts       : NotConfigured
AllowUnicastResponseToMulticast : NotConfigured
NotifyOnListen       : False
EnableStealthModeForIPsec : NotConfigured
LogFileName          : %systemroot%\system32\LogFiles\Firewall\pfirewall.log
LogMaxSizeKilobytes  : 4096
LogAllowed            : False
LogBlocked            : False
LogIgnored            : NotConfigured
DisabledInterfaceAliases : {NotConfigured}

Name                : Public
Enabled              : True
DefaultInboundAction : NotConfigured
DefaultOutboundAction : NotConfigured

```

10. Deshabilitar servicios innecesarios o inseguros

Descripción: Se deshabilitó el servicio Print Spooler para reducir la superficie de ataque.

Riesgo mitigado: Reduce posibles vulnerabilidades relacionadas con servicios innecesarios.

Validación: Se comprobó que el servicio quedó detenido y deshabilitado.

```

Administrator: Windows PowerShell
PS C:\Users\Administrator> Stop-Service -Name Spooler
PS C:\Users\Administrator> Set-Service -Name Spooler -StartupType Disabled
PS C:\Users\Administrator> Get-Service Spooler

Status  Name      DisplayName
-----
Stopped Spooler   Print Spooler

```

Conclusión

Durante esta práctica se aplicaron diferentes controles de seguridad para fortalecer el sistema operativo Windows. Las configuraciones realizadas permitieron reducir la superficie de ataque, mejorar la autenticación y limitar posibles accesos no autorizados. Además, se validó cada configuración utilizando PowerShell y políticas de grupo.